Chapter 15

User Authentication

Remote User-Authentication Principles

- The process of verifying an identity claimed by or for a system entity
- An authentication process consists of two steps:

Identification step

- Presenting an identifier to the security system

Verification step

- Presenting or generating authentication information that corroborates the binding between the entity and the identifier

Means of User Authentication

Something the individual knows

- Examples include a password, a personal identification number (PIN), or answers to a prearranged set of questions

Something the individual possesses

- Examples include cryptographic keys, electronic keycards, smart cards, and physical keys
  - This is referred to as a token

There are four general means of authenticating a user's identity, which can be used alone or in combination

Something the individual is (static biometrics)

- Examples include recognition by fingerprint, retina, and face

Something the individual does (dynamic biometrics)

- Examples include recognition by voice pattern, handwriting characteristics, and typing rhythm

- For network-based user authentication, the most important methods involve cryptographic keys and something the individual knows, such as a password

Kerberos

- Authentication service developed as part of Project Athena at MIT
- A workstation cannot be trusted to identify its users correctly to network services
  - A user may gain access to a particular workstation and pretend to be another user operating from that workstation
  - A user may alter the network address of a workstation so that the requests sent from the altered workstation appear to come from the impersonated workstation
  - A user may eavesdrop on exchanges and use a replay attack to gain entrance to a server or to disrupt operations
- Kerberos provides a centralized authentication server whose function is to authenticate users to servers and servers to users
  - Relies exclusively on symmetric encryption, making no use of public-key encryption

Kerberos

- Kerberos is a computer network authentication protocol that works on the basis of tickets to allow nodes communicating over a non-secure network to prove their identity to one another in a secure manner.
- Its designers aimed it primarily at a client–server model and it provides mutual authentication—both the user and the server verify each other's identity.

Kerberos

- The Kerberos concept uses a "master ticket" obtained at logon, which is used to obtain additional "service tickets" when a particular resource is required.
- When users log in to a Kerberos system, their password is encrypted and sent to the authentication service in the Key Distribution Center (KDC).

Kerberos

- If successfully authenticated, the KDC creates a master ticket that is sent back to the user's machine.
- Each time the user wants access to a service, the master ticket is presented to the KDC in order to obtain a service ticket for that service.
- The master-service ticket method keeps the password more secure by sending it only once at logon. From then on, service tickets are used, which function like session keys.

Kerberos Version 4

- Makes use of DES to provide the authentication service
- Authentication server (AS)
  - Knows the passwords of all users and stores these in a centralized database
  - Shares a unique secret key with each server
- Ticket
  - Created once the AS accepts the user as authentic; contains the user's ID and network address and the server's ID
  - Encrypted using the secret key shared by the AS and the server
- Ticket-granting server (TGS)
  - Issues tickets to users who have been authenticated to AS
  - Each time the user requires access to a new service the client applies to the TGS using the ticket to authenticate itself
  - The TGS then grants a ticket for the particular service
  - The client saves each service-granting ticket and uses it to authenticate its user to a server each time a particular service is requested

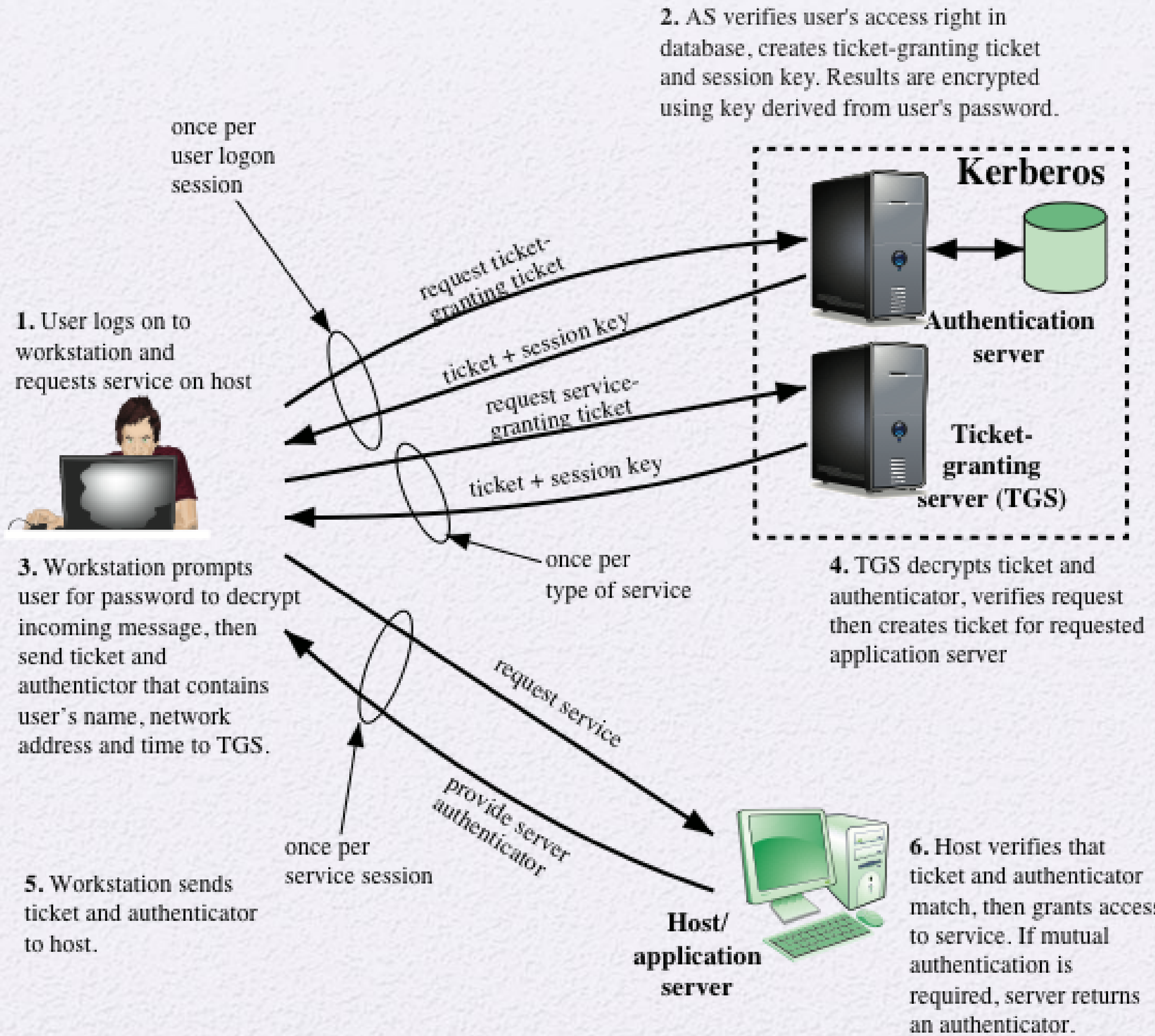

Figure 15.1 Overview of Kerberos

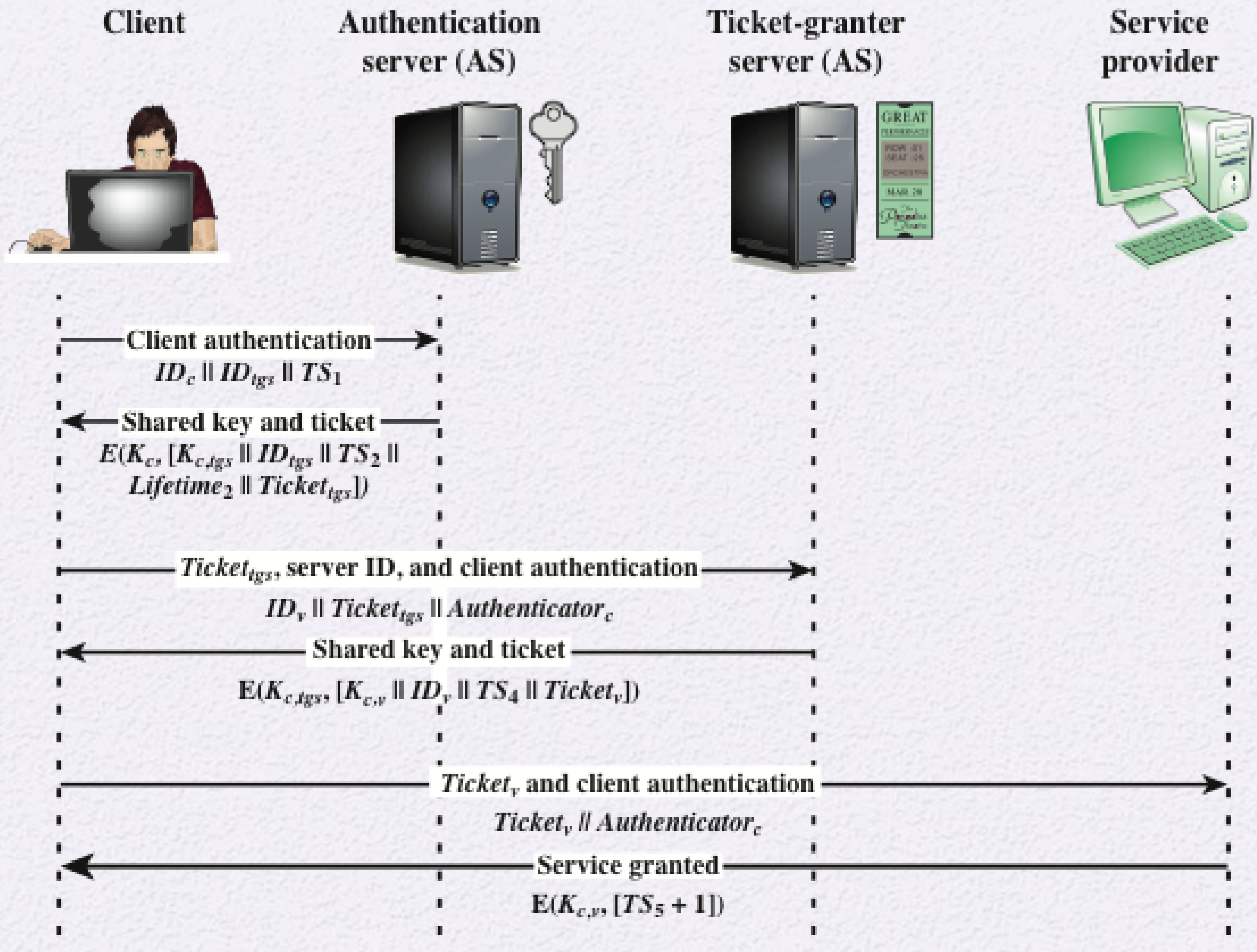

Figure 15.2 Kerberos Exchanges